

访问控制漏洞报告（Lab2：无保护的管理员功能，URL 不可预测）

1. 漏洞名称

访问控制失效（Broken Access Control） — 前端源码泄露隐藏后台路径

2. 漏洞等级

高危（High）

3. 漏洞描述

该网站的管理员后台虽然使用了不可预测的随机路径，但该路径被直接硬编码在了前端的 JavaScript 源代码中。攻击者通过查看网页源代码或拦截网页响应，即可轻易获取该隐藏路径，并绕过身份验证直接访问后台，执行删除用户等高危操作。

4. 漏洞位置

信息泄露位置：GET /（首页返回的 HTML/JS 响应体）

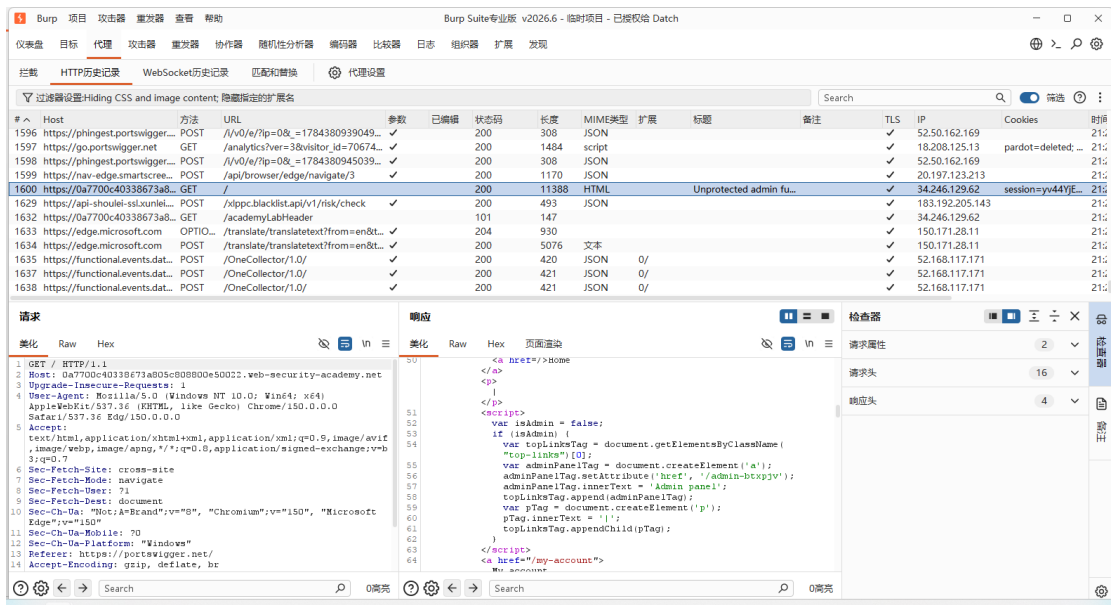
未授权访问路径：GET /admin-随机字符串

5. 漏洞复现过程

第一步：审查源码，发现隐藏的后台路径

访问网站首页，使用 Burp Suite 拦截或浏览器开发者工具查看页面的 HTML/JavaScript 源代码。

图 1：Burp 响应包中泄露隐藏后台路径



说明：开发者试图通过生成随机字符串来隐藏管理员后台，但却将这一路径直接写在了前端响应的 JavaScript 逻辑中，导致任何访问首页的用户都能读取到该敏感路径。

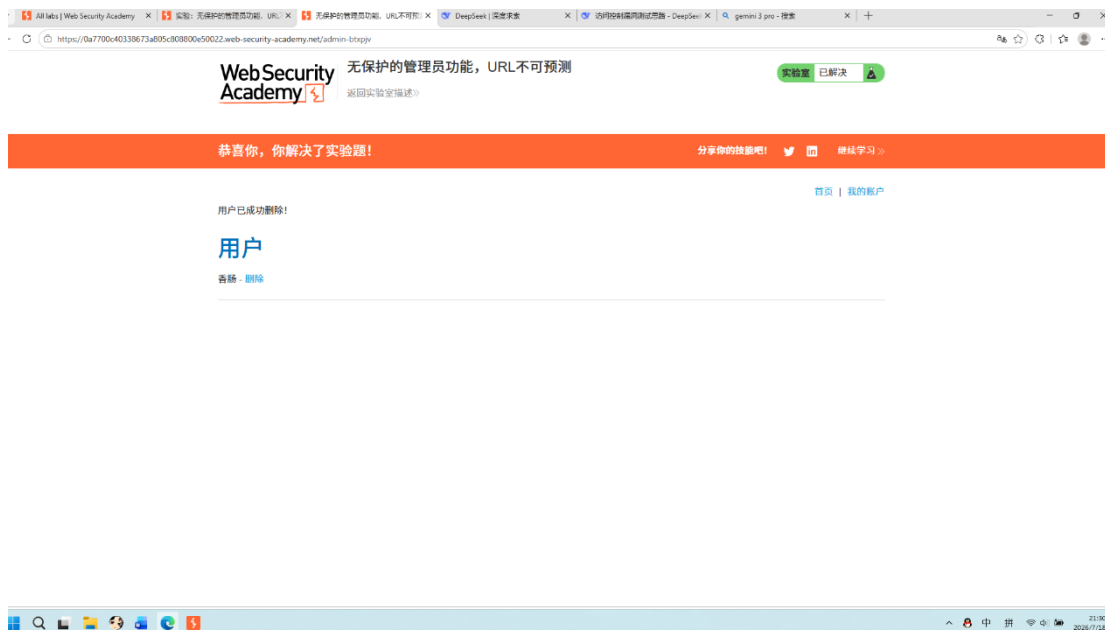
第二步：访问泄露的管理员后台

根据响应包中获取到的隐藏路径（例如 /admin-btxxpjv），在浏览器地址栏中直接拼接并访问。

第三步：执行未授权删除操作

成功进入管理员面板后，找到用户 carlos（本例中显示为中文名“香肠”，即 carlos），点击对应的“删除”按钮。

图 2：成功删除目标用户并解决实验



说明：成功利用源代码中泄露的路径，绕过保护机制删除了目标用户 carlos，验证了该访问控制漏洞的破坏性。

6. 漏洞原理

该漏洞属于客户端信息泄露导致的功能级访问控制失效。

安全防御的误区：开发者以为“随机生成的 URL 没人能猜到”，因此认为不需要加权限验证。

漏洞产生：他们将这个不可预测的路径以字符串的形式写在了客户端（浏览器）接收到的 JS 代码中。

攻击利用：任何用户（包括未登录的攻击者）只要查看网页源码，就能轻松获取这个“随机”的路径并直接访问。

7. 漏洞影响

完全绕过访问控制：攻击者无需任何凭证即可进入管理员后台。

敏感业务操作：可任意删除、修改系统数据，甚至接管整个管理权限。

8. 修复建议

- ① 切勿将敏感后台路径暴露在前端：任何动态生成的路径，都不应以明文形式出现在返回到客户端的 HTML 或 JS 文件中。
- ② 强制后端权限校验：无论 URL 多么难以预测，后端在执行 /admin-xxx 路由时，必须校验当前用户的 Session 和 Role 权限。未登录或权限不足者必须返回 403 Forbidden。
- ③ 使用双向身份验证：采用后台验证机制，如二次验证码或特定 Header 头校验。

9. 工具

Burp Suite (HTTP History 拦截与分析)

Google Chrome / Firefox (浏览器开发者工具查看源代码)

PortSwigger Web Security Academy (靶场平台)